AgriDirect AI

Crop demand prediction · Direct farmer-to-company marketplace

SECURITY & PRIVACY DOCUMENT

Security & Privacy Design

Threat model, controls, OWASP checklist and DPDP Act 2023 / Rules 2025 alignment

Version	**1.0**
Date	**24 October 2026**
Applies to	**Frontend PWA, API, ML service, workers, infrastructure**
Owner	**Development team (security champion to be named)**
Status	**Baseline — review before Phase 1 starts**

Confidential — prepared for the AgriDirect AI development team.

Contents

1. Scope and security goals . . . 3
2. Assets and data classification . . . 3
3. Threat model (STRIDE) . . . 4
4. Authentication and session design . . . 4
5. Authorization (RBAC + ownership) . . . 5
6. OWASP Top 10 (2021) checklist . . . 5
7. Application-level controls . . . 5
8. Privacy and DPDP compliance . . . 6
9. Infrastructure, logging and monitoring . . . 7
10. Incident response . . . 7
11. Secure development lifecycle . . . 7
12. Phase 0 prototype — security notes . . . 7
13. Pre-launch security checklist . . . 8

1. Scope and security goals

AgriDirect AI stores farmers' phone numbers and farm locations, companies' GST numbers, and commercially sensitive deal prices. A breach would harm farmers, damage buyer trust and attract penalties under India's DPDP Act. This document sets the minimum controls for the MVP.

Goal	Meaning for AgriDirect AI
Confidentiality	Phone numbers, exact farm locations, GSTINs and deal prices visible only to people who need them.
Integrity	Listings, offers and deal statuses cannot be forged or changed by the wrong party; every change is audited.
Availability	OTP login and advice work during the sowing season; graceful fallback when data sources fail.
Accountability	Every admin and deal action traceable to a user, time and IP.
Privacy	Collect minimum data, with notice and consent, and delete it when no longer needed.

2. Assets and data classification

Data	Class	Handling
Phone number	Personal — Confidential	Encrypted column; masked in UI to the other party until a deal is Accepted (+91 98•••••210).
Exact farm GPS location	Personal — Confidential	Stored precisely; shown to companies only as village + approximate distance (rounded to 5 km).
Name, village, district	Personal — Internal	Visible to verified counterparties.
GSTIN, company documents	Business — Confidential	Encrypted at rest; documents in private bucket; signed URLs (5 min).
Deal price and history	Business — Confidential	Only the two parties and admins.
OTP codes	Secret	Hashed (SHA-256 + pepper) in Redis with 5-min TTL; never logged.
JWT signing keys, API keys	Secret	Cloud secret manager; rotated every 90 days.
Mandi / weather / soil data	Public	No restriction; integrity checks on ingest.
Model artefacts	Internal	Private storage; versioned.

3. Threat model (STRIDE)

Threat	Example in AgriDirect AI	Controls
Spoofing	Attacker logs in as a farmer by guessing OTP; fake company posts requirements	OTP rate limits + lockout; company GST verification by admin; device/session binding
Tampering	Company changes agreed price after farmer accepts; user edits another's listing via ID	Server-side state machine; object-level authorization on every query; audit log
Repudiation	Party denies accepting a deal	Append-only deal_events with actor, timestamp, IP; SMS confirmation on Accepted
Information disclosure	Scraping all farmer phone numbers; IDOR on /listings/{id}	Masked phones; UUIDs; RBAC + ownership checks; pagination limits; rate limiting
Denial of service	SMS pumping (OTP flood costs money); API flooding	Per-number, per-IP and global OTP caps; CAPTCHA after 2 requests; WAF; autoscaling
Elevation of privilege	Farmer calls /admin endpoint; JWT role edited	Role read from DB/claims signed server-side; admin routes behind separate RBAC + MFA

3.1 Abuse cases specific to the marketplace

- **Fake buyer scam:** fraudster poses as a company, wins a deal, collects produce without paying. → Only verified companies can post; show verification badge; warn farmers never to release goods before agreed payment terms; rating system.
- **Fake listings:** spam or price manipulation. → Phone-verified farmers, listing limits per day, flagging, admin moderation.
- **Taking contacts off-platform early:** → Reveal phone only after Accepted.
- **Data poisoning:** fake requirements to distort demand signals. → Only verified companies' open requirements count; cap influence per company.

4. Authentication and session design

Control	Specification
OTP	6 digits from CSPRNG; 5-minute expiry; single use; constant-time compare.
OTP send limits	3 per number per 15 min; 10 per IP per hour; global daily budget alert; Indian numbers only (+91).
OTP verify limits	5 wrong attempts → 30-min lock for that number.
Access token	JWT (EdDSA or RS256), 15-min expiry; claims: sub, role, ver; no PII in token.
Refresh token	Opaque random 256-bit, stored hashed; httpOnly + Secure + SameSite=Strict cookie; 7-day; rotated on every use; reuse detection revokes the family.
Logout	Revokes refresh token; token version bump logs out all devices.
Admin accounts	OTP + TOTP second factor; IP allow-list optional; sessions 8 hours max.
SMS provider	DLT-registered sender ID and templates (TRAI requirement).

5. Authorization (RBAC + ownership)

Resource	Farmer	Company (verified)	Company (pending)	Admin
Own profile	Read/Write	Read/Write	Read/Write	Read
Listings	CRUD own	Read active	Read active	Read, hide
Requirements	Read (aggregate)	CRUD own	—	Read, hide
Deals	Own as party	Own as party	—	Read
Farmer phone	—	After Accepted	—	Read (audited)
Admin endpoints	—	—	—	Yes

Rule: every query on a user-owned resource filters by the caller's ID on the server (e.g., *WHERE farmer_id = :current_user*). Never trust IDs or roles from the request body.

6. OWASP Top 10 (2021) checklist

Risk	Control in AgriDirect AI	Verified by
A01 Broken access control	RBAC dependency on every router; ownership filters; deny by default	API tests per role; ZAP
A02 Cryptographic failures	TLS 1.2+ everywhere, HSTS; AES-256 at rest; field encryption for phone/GSTIN	SSL Labs A; config review
A03 Injection	SQLAlchemy parameterised queries; Pydantic validation; no raw SQL string building	Code review; ZAP
A04 Insecure design	Threat model (this doc); deal state machine on server	Design review
A05 Security misconfiguration	Debug off in prod; CORS allow-list; security headers (CSP, X-Frame-Options, Referrer-Policy)	Header scan
A06 Vulnerable components	pip-audit, npm audit, Dependabot; pinned versions	CI gate
A07 Identification & auth failures	Section 4 controls	Auth test suite
A08 Software & data integrity	Signed images; protected main branch; data checksums on ingest	CI config
A09 Logging & monitoring failures	Audit log, Sentry, alerts (Section 9)	Alert test
A10 SSRF	No user-supplied URLs fetched; outbound allow-list for data sources	Code review

7. Application-level controls

7.1 API

- Rate limiting: 60 req/min per user, 20 req/min unauthenticated per IP; stricter on search.
- Request body limit 1 MB (uploads via pre-signed URLs, 5 MB per photo).
- Strict Pydantic schemas with *extra = forbid*; enums for statuses.
- Pagination maximum 50 items; no endpoint returns all users or all phones.

- Problem+json errors without stack traces or SQL details.

7.2 Frontend / PWA

- Content-Security-Policy: default-src 'self'; img-src self + storage domain + tile server; no inline scripts in production.
- Access token kept in memory only; never in localStorage.
- React escaping by default; no dangerouslySetInnerHTML with user text.
- Service worker caches only public assets and non-sensitive advice, never deal or profile responses.

7.3 File uploads

- Direct-to-bucket via pre-signed PUT URL restricted by content type and size.
- Server re-encodes images, strips EXIF (including GPS), and scans with ClamAV before publishing.
- Random object keys; bucket private; read via short-lived signed URLs.

7.4 ML service

- Not exposed to the internet; called only by the API on a private network.
- Input validation on crop/district IDs; model files loaded only from the internal registry (no pickle from user input).
- Ingested data validated for schema and range to limit poisoning.

8. Privacy and DPDP compliance

The Digital Personal Data Protection Rules, 2025 were notified on 13 November 2025 with a phased rollout; most operational duties (notice, consent, security safeguards, breach intimation, retention) apply from about 13 May 2027. AgriDirect AI should comply from launch rather than retrofit.

DPDP principle	Implementation
Notice	Plain-language notice in English, Hindi and Marathi at sign-up: what data, why, how long, rights, grievance contact.
Consent	Separate checkboxes: (1) account and marketplace operation, (2) optional marketing messages. Consent record stored with timestamp and notice version.
Withdraw consent	Settings → Privacy → withdraw; as easy as giving it.
Purpose limitation	Phone used for login and deal communication only; location for matching and advice only.
Data minimisation	No Aadhaar, bank details or date of birth collected in MVP.
Accuracy	Users can edit profile any time.
Storage limitation	Inactive accounts (24 months) notified then deleted; deleted accounts purged in 30 days; deal records kept anonymised for analytics.
Security safeguards	Encryption, access control, logging, backups (Sections 4–9).
Breach intimation	Notify affected users and the Data Protection Board without delay; detailed report within the period the Rules prescribe (72 hours).
Rights of data principals	Access, correction, erasure, grievance redressal and nomination via in-app request; response tracked with SLA well inside the prescribed maximum.
Children	Users must confirm they are 18+; no knowing processing of minors' data.

DPDP principle	Implementation
Processors	Data processing agreements with SMS, cloud and map providers; data hosted in India.

> Have the client's legal advisor confirm the final notice text, retention periods and whether the platform could be notified as a Significant Data Fiduciary later. This document is engineering guidance, not legal advice.

9. Infrastructure, logging and monitoring

- Hosting in AWS Mumbai (or Indian cloud); VPC with public subnet for load balancer only; DB and Redis in private subnets.
- Security groups least-privilege; no SSH from internet (use SSM / bastion with MFA).
- Encrypted volumes and backups (KMS); daily snapshots, 30-day retention; quarterly restore drill.
- WAF on the load balancer with managed rule sets and rate-based rules.
- IAM: separate roles per service; no long-lived keys in code; MFA for all console users.
- Logs: JSON, 90-day retention; PII redaction middleware (phones, OTPs, tokens).
- Alerts: spike in OTP sends, failed logins, 403s, admin actions outside office hours, pipeline failure.

10. Incident response

Step	Action	Owner / time
1. Detect	Alert or report received; open incident channel	On-call, immediately
2. Contain	Revoke keys/tokens, block IPs, disable affected feature	Tech lead, < 1 hour
3. Assess	What data, how many users, since when	Tech lead + client, < 24 hours
4. Notify	Affected users and Data Protection Board per DPDP Rules; client stakeholders	Client (Data Fiduciary)
5. Recover	Patch, restore, monitor	Dev team
6. Review	Blameless post-mortem; update this document	All, within 7 days

11. Secure development lifecycle

1. Security requirements in every user story (who can do this? what is logged?).
2. Threat-model review for new features touching auth, deals or personal data.
3. Pre-commit: gitleaks secret scan; linting.
4. CI: tests, pip-audit, npm audit, Semgrep rules; block on high severity.
5. Staging: OWASP ZAP baseline scan each release.
6. Before launch: external penetration test or structured peer review using OWASP ASVS Level 1.
7. Monthly dependency updates; key rotation every 90 days.

12. Phase 0 prototype — security notes

- The college demo is static frontend with mock data: no real personal data, no OTP is sent, nothing is stored on a server.
- Mock names and phone numbers are fictional; do not enter real farmer data during demos.

- The demo login accepts any 6-digit code — clearly labelled "Demo mode" on the screen.
- Before Phase 1, remove mock auth and enable every control in Sections 4–9.

13. Pre-launch security checklist

#	Item	Done
1	OTP limits and lockout tested	☐
2	Role and ownership tests pass for every endpoint	☐
3	Phones masked until Accepted	☐
4	TLS A rating; HSTS on	☐
5	CSP and security headers present	☐
6	No secrets in repo (gitleaks clean)	☐
7	Dependency scan: no high/critical	☐
8	Backups restored successfully once	☐
9	Logs free of PII and OTPs	☐
10	Privacy notice + consent capture live in 3 languages	☐
11	Admin MFA enforced	☐
12	ZAP baseline: no high findings	☐